APPROVEDESK

Security Assessment

Repository-wide static security review

72%

MODERATE

Needs remediation before high-assurance use

APPLICATION VERSION	v2.7.2
GIT REVISION	ec9a7eb69740b66ebdaaa94d724b012c3b64b0df
ASSESSMENT DATE	27 August 2026
SCAN TYPE	Codex Security Standard repository scan
SCAN ID	45c35a78-2be6-4c9e-9d36-a3d19204d30c

Executive assessment

ApproveDesk v2.7.2 has a moderate security posture. The review validated five exploitable application risks: one High-severity authorization weakness and four Medium-severity issues involving outbound requests, API token scope, spreadsheet import, and spreadsheet export. No Critical findings were identified.

The application also demonstrates strong controls in its most sensitive workflow areas. Approval state transitions are serialized and policy checked, workflow actions remain append-only in application logic, attachments are private and authorization-bound, backup restoration verifies integrity and archive safety, and signed approval channels re-check actor and step eligibility.

Overall rating	**72 / 100 - Moderate**
Reportable findings	5
Severity	1 High, 4 Medium, 0 Low, 0 Critical
Confidence	High confidence for all reportable findings
Coverage	Partial across 899 tracked files; critical surfaces prioritized
Testing	Offline static review; no runtime penetration test

How to read the percentage

The 72% rating is a transparent, risk-weighted engineering score. It is not the probability that the application is secure and it is not a certification. A High-severity privilege-escalation flaw caps the present rating. Points are also withheld for four validated Medium findings, partial review coverage, lack of runtime testing, and production controls that could not be observed from source code.

Installer control

CONTROLLED - NOT SCORED AS A VULNERABILITY
The first-run installer is intentionally retained and, according to the supplied deployment context, restricted to an allowed IP address. This item is recorded as informational and does not reduce the 72% score. The allow-list should remain fail-closed at every ingress and the post-install lock should be tested after deployment.

Score methodology

Each domain is weighted according to the confidentiality, integrity, and availability impact it protects. Scores reflect source-backed controls and validated weaknesses at this revision.

Security domain	Weight	Score	Basis
Identity and authentication	10	9	Strong session, OAuth, registration, and active-user controls.
Authorization and role delegation	15	6	High-severity self-escalation through built-in role assignment.
API token enforcement	10	6	Submission detail omits the independent submissions:read scope.
Workflow and audit integrity	15	15	Transactional locks, current-step checks, delegation checks, append-only actions.
Input, import, and export safety	15	6	Formula injection and unbounded spreadsheet expansion.
Files, backups, and data integrity	15	15	Private delivery, authorization binding, archive and hash validation.
Outbound network safety	10	6	Web-push redirect chain bypasses destination validation.
Secrets and deployment safeguards	10	9	No tracked production secret; installer IP control is external and unverified.
Total	**100**	**72**	**Moderate security posture**

Severity distribution

Severity	Count	Treatment
Critical	0	None identified
High	1	Remediate before high-assurance production use
Medium	4	Schedule promptly and verify with regression tests
Low	0	None identified
Informational	1	Installer control accepted; verify operationally

Validated findings

HIGH

1. Delegated user editor can assign themselves a role above their permission ceiling

Classification: CWE-269 - Improper Privilege Management

Impact: A user with users.update can grant themselves department-head, gaining organization-wide access to confidential submissions and attachments.

Exploit path: users.update -> edit own account -> select department-head -> syncRoles -> submissions.view.all

Evidence: app/Services/Users/GrantableRoleService.php:31-42; app/Policies/UserPolicy.php:19-29; app/Services/Roles/RoleAssignmentService.php:18-58

Required remediation: Apply permission ceilings to every built-in and custom role. Prohibit non-owner self-role changes and separate profile editing from role administration. Add negative tests for self-escalation and grants above the actor's own permissions.

MEDIUM

2. Web-push delivery follows attacker-controlled redirects to private networks

Classification: CWE-918 - Server-Side Request Forgery

Impact: An authenticated requester can cause blind requests toward private, loopback, or link-local targets when notification delivery follows a redirect.

Exploit path: stored public push endpoint -> validation pin discarded -> default Guzzle redirect -> internal target

Evidence: app/Services/Notifications/WebPushService.php:60-75; app/Http/Controllers/PushSubscriptionController.php:13-29

Required remediation: Disable redirects in the actual web-push transport and use the validated DNS pin for the connection. If redirects are ever required, validate and pin every hop. Test IPv4, IPv6, loopback, private, and link-local redirects.

MEDIUM

3. Submission detail API ignores the personal access token read ability

Classification: CWE-862 - Missing Authorization

Impact: A valid token without submissions:read can retrieve confidential submission and workflow data when the token owner has user-level view access.

Exploit path: limited bearer token -> Sanctum -> user policy only -> SubmissionResource

Evidence: app/Http/Controllers/Api/V1/SubmissionController.php:75-80; routes/api.php:16-33; app/Http/Resources/Api/V1/SubmissionResource.php:15-42

Required remediation: Require submissions:read through route ability middleware or a FormRequest before policy authorization. Test that write-only and approvals-only tokens receive 403 while read tokens still remain subject to model policy.

Validated findings - continued

MEDIUM

4. User spreadsheet import lacks decompressed-size and worksheet limits

Classification: CWE-409 - Improper Handling of Highly Compressed Data

Impact: A delegated importer can exhaust memory or CPU on shared hosting with a compressed XLSX that expands into a very large workbook or worksheet.

Exploit path: 10 MB upload -> IOFactory::load -> expanded XML/shared strings -> Worksheet::toArray -> worker exhaustion

Evidence: app/Services/Users/UserImportService.php:39-51 and 323-336; resources/views/pages/admin/users-import.blade.php:26-49

Required remediation: Inspect ZIP expansion and worksheet dimensions before full parsing. Cap rows, columns, cells, and shared strings; use read filters and streaming iteration instead of toArray. Add high-compression and oversized-dimension rejection tests.

MEDIUM

5. Attacker-controlled data is exported as executable spreadsheet formulas

Classification: CWE-1236 - Improper Neutralization of Formula Elements

Impact: A requester can place formula-prefixed content in a submission. When an authorized recipient opens a CSV or XLSX export, a compatible spreadsheet client may execute it, potentially disclosing data or invoking unsafe client features.

Exploit path: submission title or custom field -> analytics data -> CSV/XLSX cell -> spreadsheet formula evaluation

Evidence: app/Services/AnalyticsExportService.php:77-85 and 149-190; app/Services/AnalyticsService.php:249-265

Required remediation: Neutralize dangerous CSV prefixes and write all untrusted XLSX values explicitly as string cells. Test equals, plus, minus, at-sign, tab, carriage-return, and leading-whitespace variants.

Risk interpretation

The authorization finding should be addressed first because it enables a delegated administrator to expand their own access inside the product. The Medium findings require either an authenticated capability, a valid token, or a recipient opening an export, but each has a concrete and source-backed path to impact.

Verified security controls

Workflow integrity	Current-step authorization, active delegation checks, duplicate-action prevention, database transactions, and lockForUpdate were confirmed.
Signed approval channels	Email, Slack, and Teams actions enforce expiry, signatures or HMAC capability, step binding, actor eligibility, and WorkflowEngine rechecks.
Attachment security	Private disk storage, MIME and size limits, signed routes, parent-resource binding, policy authorization, and nosniff delivery were confirmed.
Backup and restore	The v2.7.2 restore path verifies size, SHA-256, exact manifests, per-file hashes, ZIP-entry limits, path containment, and safe promotion.
Rich text	Server-side allow-list sanitization and repeat sanitization at raw-render sites reduce stored cross-site scripting risk.
OAuth and registration	State, PKCE, fixed endpoints, identity uniqueness, active-user enforcement, and allowed-domain checks were confirmed.
Webhook and connectors	Reviewed clients use destination pinning, TLS verification, disabled redirects, and suppressed response bodies.
Branding custom code	Intentional executable branding code is restricted to the non-delegable System-owner capability.
Secrets	Reviewed credential fields are encrypted or redacted, and no tracked production credential was confirmed.
Website file resolver	Dot-segment rejection, realpath containment, and extension allow-listing were confirmed.

No issue found means that the reviewed source paths contained effective controls against the tested threat model. It does not prove the absence of defects elsewhere or in the deployed environment.

Remediation plan

Priority	Action	Verification gate
P1	Enforce role permission ceilings for all roles and block non-owner self-role changes.	Negative role-grant and self-escalation tests pass.
P2	Enforce submissions:read on the detail API independently of model policy.	Limited-token matrix returns expected 403/200 results.
P2	Disable web-push redirects and bind the connection to validated DNS results.	Redirect-to-private tests prove no second request occurs.
P2	Neutralize formulas in CSV and force untrusted XLSX cells to string type.	All dangerous prefixes remain inert in exported files.
P2	Preflight XLSX expansion and dimensions, then stream bounded worksheet data.	Zip-bomb and oversized-sheet fixtures fail before full parsing.
Ops	Keep installer allow-listing fail-closed and verify the installed.lock behavior after installation.	Requests from disallowed IPs fail at every ingress; installer refuses access after lock creation.

Projected posture

Fixing and independently verifying the High-severity role escalation would remove the principal score cap. Closing all four Medium findings and repeating runtime-focused security tests should move the application toward a strong posture. Any future score must be based on verification of the actual fixes, not the remediation plan alone.

Release gate

- Add regression tests for every finding and run the complete parallel test suite.
- Run the formatter and repository security scan again against the remediation revision.
- Verify the installer IP allow-list from an allowed and a disallowed address.
- Perform a focused runtime test for SSRF redirect behavior, token scopes, imports, and exports.

Scope, evidence, and limitations

Target	ApproveDesk v2.7.2
Revision	ec9a7eb69740b66ebdaaa94d724b012c3b64b0df
Mode	Repository-wide Standard static security audit
Reviewed	Laravel source, routes, policies, actions, services, migrations, configuration, security-sensitive views, relevant tests, and dependency source needed to validate concrete dataflows
Canonical evidence	scan-manifest.json, findings.json, coverage.json, report.md, and results.sarif
Scan ID	45c35a78-2be6-4c9e-9d36-a3d19204d30c

Limitations

- This was an offline source review, not a penetration test of a deployed instance.
- Coverage was partial across 899 tracked files; security-critical surfaces were prioritized.
- The external installer IP restriction and production TLS, proxy, database, filesystem, egress, and logging controls were not independently observable.
- No online dependency-advisory lookup was performed.
- Optional AWS S3 SDK packages are absent at this revision; outbound pinning must be re-reviewed if S3 support is enabled later.

Open operational questions

- Is the installer allow-list enforced at every ingress and configured to fail closed?
- Do production database grants and cascades preserve workflow_actions immutability?
- Are production TLS, proxy, filesystem, logging, and egress controls configured as documented?
- Will future S3 enablement bind the actual SDK connection to a validated destination?

Assessment statement: This document reports source-backed findings at one Git revision. Security changes over time and depends on deployment configuration, operations, dependencies, and future code. The percentage is intended for prioritization and communication; it is not a warranty, certification, or guarantee against compromise.